Osservatorio sicurezza dello spazio cibernetico italiano - OSSCI



Introduzione 3

Motivazioni 3

Obiettivi Specifici 3

Metodologia 4

Pipeline di elaborazione dati 5

- **Pipeline 0: Ambito dello Spazio Cibernetico Italiano** 6
- **Pipeline 1: Asset Inventory Nazionale** 6
- **Pipeline 2: Stato delle vulnerabilità dello spazio cibernetico italiano** 8
- **Pipeline 3: Alerting automatico di vulnerabilità** 8

Formato dei dati prodotti 9

Linee guida implementative 9

Politica di pubblicazione 10

- **Licenza di distribuzione del software e dei dati** 10

Gestione operativa della produzione dati 11

- **Operatività legale** 11
- **Comunicazione preventiva alle istituzioni** 12
- **Comunicazione preventiva a operatori di telecomunicazioni** 12
- **Accettazione Termini di Utilizzo dei Dati** 13
- **Sorgenti IP delle attività** 13
- **Spazi IP di scansione e Abuse** 13

Esperienze di Internet scanning all’estero 14

Introduzione

L'obiettivo dell'Osservatorio Sicurezza dello Spazio Cibernetico Italiano (OSSCI) è quello di migliorare la sicurezza informatica delle infrastrutture connesse a Internet attraverso una misurazione attiva e continuativa del perimetro Internet nazionale, e la pubblicazione di dati a disposizione del pubblico e degli specialisti di settore per ulteriori elaborazioni e progettualità.

OSSCI vede la sua organizzazione preliminare tramite group chat telegram di libero accesso e partecipazione oltreché un Github repository dove collaborativamente viene sviluppato il software oltreché messi a disposizione i dati da questo prodotti.

Motivazioni

Attualmente non esiste una misurazione indipendente del livello di sicurezza e/o di vulnerabilità dello spazio cibernetico italiano, come d'altronde non esiste una definizione tecnica di cosa questo sia e come si determini se non in un ambito normativo italiano.

Esistono funzioni preposte nel quadro istituzionale (DIS e CERT) per identificare i soggetti giuridici e le loro infrastrutture, addirittura potendo intervenire con sanzioni laddove questi avessero problematiche di sicurezza e non venissero risolte.
Tuttavia non esiste nello scenario nazionale alcun progetto di misurazione con rendicontabilità pubblica dello stato delle vulnerabilità che porti, attraverso il monitoraggio continuo automatizzato e la notifica agli stakeholder, a un miglioramento del livello complessivo di sicurezza informatica.

Obiettivi Specifici

L'osservatorio si pone l'obiettivo di migliorare **la sicurezza dello spazio cibernetico italiano**, misurandolo periodicamente, fornendo dati e software per informare e far porre rimedio ai problemi di sicurezza eventualmente riscontrati.

Obiettivi specifici sono:

1. Misurare con metodi omogenei la sicurezza delle infrastrutture sottoposte alla normativa italiana con periodicità bisettimanale.
2. Produrre i data set, e il software che li producono, secondo una logica di piena riproducibilità da parte della comunità della ricerca scientifica nell'ambito della sicurezza cibernetica, con tutti i servizi server raggiungibili da Internet, quali tipologie di software hanno in esecuzione e quale versione/edizione.

3. Fornire un archivio di data set raccolti con periodicità, stimolare e favorire la nascita di progetti di cybersecurity che ne facciano uso

Fra i primi ambiti di applicazione, che riteniamo debbano essere sviluppati come tool di fruizione dei dati, troviamo:

- Produrre un data set arricchito rappresentante **lo stato delle vulnerabilità Internet dello spazio cibernetico italiano**.
  Questo realizzato interpolando i data set della scansione con basi dati di vulnerabilità per evidenziare sistemi con edizioni di software a rischio di attacco informatico.

- Realizzare servizi di alerting automatici ai responsabili dei sistemi vulnerabili, oltreché agli operatori di telecomunicazioni presso cui questi sono interconnessi, segnalando e informando della problematica di sicurezza

Questa attività, usando il software prodotto, potrebbe essere effettuata ad esempio da CERT nazionali, i quali verso la PA potrebbero eventualmente effettuare controlli più approfonditi.

Metodologia

OSSCI, per raggiungere tale risultato, prevede una scansione non intrusiva dei servizi Internet esposti sullo spazio cibernetico italiano, con tutta la sua complessità e incertezza di definizione tecnica.

Cercherà inoltre di enumerare i sistemi applicativi offerti dai servizi identificati, evidenziando la tipologia di software in esecuzione sul server e la sua versione.

Tale scansione avrà cadenza bisettimanale ed i suoi risultati verranno redatti e pubblicati in un formato grezzo e machine-readable per favorire ulteriori attività di ricerca e progettualità.

Lo spazio cibernetico italiano verrà identificato secondo una metodologia documentata e replicabile, descritta nella sezione lo “**Spazio Cibernetico Italiano**” (SCI).

I dati pubblicati saranno arricchiti di tutti i metadati disponibili/estraibili per tramite della interpolazione di basi dati pubbliche (interrogabili in tempo reale o acquisibili con modalità bulk).

Di particolare rilevanza è la misurabilità empirica dei risultati in termini di miglioramento della sicurezza dello spazio cibernetico italiano, interpolando i dati delle diverse produzioni di dati nelle sue serie storiche, prodotte su base bi-settimanale.

Ad esempio misurando il primo data set e il ventiseiesimo dopo un anno, sarebbe possibile estrarre indicatori qualitativi e quantitativi (e.g. Quantità % di siti web con CMS non aggiornati

sul totale dei siti web raggiungibili pubblicamente tramite Internet alla prima raccolta dati e all'ultima dopo un anno).

Pipeline di elaborazione dati

L'intero progetto sarà realizzato con una serie di pipeline di elaborazione dati che hanno lo scopo di rendere il dataset aperto. Lo scopo finale è la creazione di valore aggiunto per il miglioramento dell'ecosistema della ricerca della sicurezza distribuito.

Le **Pipeline 0** produrrà l'elenco completo degli indirizzi in ambito che rappresentano lo "spazio cibernetico italiano" e dei metadati che sono ivi rappresentati (vedi "Pipeline 0: Spazio Cibernetico Italiano"). L'output della pipeline 0 sarà generato dall'implementazione di diverse metodologie - tramite implementazioni automatiche e/o manuali. Ulteriori input potranno essere generati dalle altre pipeline.

La **Pipeline 1** arricchirà i metadati relativi alla Pipeline 0 sia attraverso metodologie di raccolta di *informazioni passive* - senza l'interazione diretta con gli indirizzi in ambito - analizzando le "emanazioni" che i sistemi in ambito hanno prodotto (es. RRDNS), sia metodologie di raccolta di *informazioni attivo/interattive* - cioè interagendo con gli indirizzi in ambito - in maniera comunque legittima (es. simulando la navigazione Internet di un utente "normale") così da limitare eventuali rischi di natura tecnica e/o legale (vedi "Pipeline 1: Asset Inventory Nazionale").

A mero titolo esemplificativo, l'arricchimento passivo in Pipeline 1 può includere metadati come quelli relativi all'Autonomous System Number, Operatore di riferimento, intestazione dell'organizzazione responsabile, Nomi a dominio, reverse dns, descrizione della rete, contatto email di abuse dell'operatore, contatto email di abuse dell'owner della rete, etc.

Come ulteriore esempio di arricchimento attivo, tramite tecniche interattive, si potrebbe produrre una mappatura completa, massiva, aggiornata e non-intrusiva dei servizi server esposti su Internet.

Queste prime due pipeline rappresentano i principali obiettivi di OSSCI come produzione di dati.

Secondariamente, in funzione delle risorse ma anche tramite il contributo di soggetti terzi comunitari (siano essi società civile o istituzionali), potranno essere ulteriormente sviluppate e prodotte altre pipeline di elaborazione dati quali a mero titolo esemplificativo una **Pipeline 2** per l'interpolazione delle informazioni nell'Asset Inventory con quelle relative a vulnerabilità note e una **Pipeline 3** per produrre un servizio di alerting agli owner dei servizi.

Pipeline 0: Ambito dello Spazio Cibernetico Italiano

L'identificazione dello spazio cibernetico italiano (SCI) rappresenta senz'altro uno degli aspetti più articolati e sensibili, non potendosi limitare a verificare solo "gli indirizzi IP italiani", essendo lo spazio cibernetico italiano ben più ampio.

Questi dati saranno l'output prodotto della Pipeline 0, che saranno poi soggetti ad arricchimento tramite le altre pipeline.

Si pensi a titolo di esempio ad un Autonomous System (AS) geolocalizzato all'estero ma instradato verso una infrastruttura in Italia, oppure un servizio di soggetti giuridici (pubblici o privati) italiani ospitato su un'infrastruttura cloud pubblica (ad es. AWS in Germania). È parte del SCI?

Per tale ragione l'identificazione del perimetro dello spazio cibernetico italiano richiederà della attività di ricerca e consensus, con un diverse metodologie e analisi manuali.

Sarà necessaria una pluralità di tecniche per la sua determinazione, e le medesime modalità di identificazione saranno in seguito riportate all'interno dei data set.

A titolo di esempio possono considerate delle fonti di dati che confluiscono a definire lo spazio cibernetico italiano:

1. Spazi di indirizzamento IP italiani:
    a. Identificazione dei netblock (RIPE NCC o altri RIR) che fanno riferimento a soggetti Italiani.
    b. Estrapolazione degli AS number dai feed BGP presso gli Internet exchange italiani (con alcuni filtri: Rif. Chiedere a Marco D'Itri), identificazione degli annunci di tali soggetti e quindi dei sistemi in ambito
2. IndicePA: I siti delle PA italiane che risultano da IndicePA mantenuto da Agid
3. Website Ranking lists: Da Alexa e Tranco List tutti i siti Internet con dominio .it.
4. Tutti i domini .it che risultano dal DNS reverse scan degli IP italiani
5. Tutti gli hostname che escono fuori tramite $METODICHE_DI_DNS_INTELLIGENCE
6. Altro da ricercare

Pipeline 1: Asset Inventory Nazionale

Le metodologie che è possibile implementare per arricchire le informazioni sui sistemi in ambito sono innumerevoli.
Tuttavia non tutte sono effettuabili considerando due categorie di limitazioni principali:

- Legali, relative al rischio di effettuare un accesso abusivo a sistema informatico e/o danneggiamento;

- Tecniche, relative alla complessità e/o costo di esecuzione o elevata probabilità di falsi positivi.

Per tali motivi le attività che genereranno le informazioni avranno il solo scopo di fornire metadati sui sistemi e si limiteranno ad identificare i servizi esposti su Internet, senza alcuna attività intrusiva o richieste anomale: riprodurranno delle attività legittime, limitando quindi i rischi connessi ai fattori di cui sopra.

Ciò faciliterà l'identificazione di problematiche di sicurezza informatica e la comunicazione relativa ad esse.

Attività di raccolta di informazioni passiva:

- Risoluzione DNS degli indirizzi, anche inversa;
- Identificazione degli intestatari dei servizi tramite query inverse sui nomi a dominio.

Attività di raccolta di informazioni attiva/interattiva:

- Identificazione delle porte aperte TCP in un range inclusivo dei principali servizi esposti e, laddove fattibile come impegno, anche tutte le porte TCP.
- Scansione dei servizi e delle porte UDP in un range predefinito.
- Identificazione dei servizi offerti tramite le porte TCP/UDP e dei software sottostanti (e.g. Web, VPN, SCTP, etc), nel limite di un "educated guess" soggetto a falsi positivi.
- Identificazione di ulteriori protocolli/servizi utilizzati oltre a quelli citati.
- Identificazione di problematiche sui protocolli, configurazioni e/o aggiornamenti software, policy compliance, e.g.:
    - Per i servizi Web identificazione del software utilizzato sia a livello di server che a livello applicativo (e.g. tipologie e versioni di interpreti, framework, CMS e relativi plugin e/o altri software).
    - Per i servizi cifrati, identificazione delle versioni dei protocolli di cifratura e della loro configurazione (e.g. TLS, HTTPS, SMTP/TLS, IMAPS, IMAP/TLS, etc).
    - Raccolta di ulteriori informazioni utili allo scopo, interagendo con gli indirizzi dello SCI.

Tale scansione fornirà un Asset Inventory degli indirizzi in ambito, del sottoinsieme delle porte aperte identificate, dei servizi esposti e delle loro versioni e configurazioni.

Dai dati ottenuti dalla pipeline di scansione indicata, sarà possibile inferire logicamente la presenza di eventuali vulnerabilità di vario genere (es. software non aggiornati, protocolli insicuri), senza causare disservizi o accessi abusivi.
I dati prodotti dal software sono generati secondo quanto definito nel formato di dati aperti nella sezione Formato dei dati prodotti.

Pipeline 2: Stato delle vulnerabilità dello spazio cibernetico italiano

Interpolando i dataset della scansione (es. banner dei servizi) con basi dati di vulnerabilità sarà possibile evidenziare eventuali vulnerabilità (es. versioni di software con potenziali vulnerabilità in quanto obsoleti o non aggiornati), utilizzo di configurazioni insicure (es. cifrari deboli) o problematiche legate alle policy (es. invio di password su canale non cifrato) o di altra tipologia, sarà possibile determinare un dataset rappresentante **stato delle vulnerabilità dello SCI**.

L'implementazione tecnica potrà richiedere più approcci, rivolti alla riduzione del falsi positivi fra edizione di software effettivamente rilevata e incrocio con basi dati di vulnerabilità.

Questo aspetto di natura tecnica merita un approfondimento valutando le tipologie meno intrusive per aumentare l'efficacia di rilevamento e la riduzione di falsi positivi al minimo tecnicamente possibile.

Pipeline 3: Alerting automatico di vulnerabilità

Interpolando i dati di contatti email relativi alle reti provenienti dalla Pipeline 0, con le problematiche di sicurezza identificate dalla Pipeline 2, sarà realizzata una funzionalità di alerting automatico ai responsabili dei sistemi vulnerabili, oltreché agli operatori di telecomunicazioni presso cui questi sono interconnessi.

Verranno informati della problematica di sicurezza.

Questa attività, usando il software prodotto, potrebbe essere effettuata anche ad esempio da CERT nazionali, dove verso la PA potere eventualmente effettuare controlli più approfonditi nella Pipeline 1 di produzione dati.

Idealmente l'esistenza di un soggetto terzo che effettua questa attività, stimolerà le istituzioni e gli operatori telefonici ad adottare le medesime metodologie.

Iniziative come ShadowServer effettuano anche scansioni di Internet per le vulnerabilità più comuni e in una logica di opt-in, consentono di ricevere alert di vulnerabilità, tuttavia non mettono a disposizione liberamente i dati di scansione né il software per la produzione dei dati. Differentemente da ShadowServer il progetto OSSCI si propone di rendere i dati di scansione pubblici come il software opensource che li produce, effettuare una scansione più approfondita oltre ad effettuare un alerting proattivo senza opt-in.

Formato dei dati prodotti

I formati dei dati prodotti potranno essere molteplici, per facilitare tanto l'elaborazione da parte di software (es: output.json di zmap come standard di riferimento), quanto in chiave di accessibilità con strumenti di analisi e visualizzazione dati di base (spreadsheet).

Saranno sviluppati dalla comunità strumenti di visualizzazione web ed elaborazione dei dati che facciano impiego dei dataset prodotti dall'osservatorio.

I dati sono al centro del progetto, per stimolare al massimo la creatività e le energie della comunità nella possibilità di generare valore e sperimentare attraverso l'uso dei dati.

Linee guida implementative

La realizzazione del software a supporto, necessariamente opensource ai fini di replicabilità del progetto, deve rispettare le seguenti linee guida:

- Minima quantità di righe di codice scritte al fine di ridurre la complessità;
- Riutilizzo di strumenti opensource esistenti ove disponibili, maturi ed adatti allo scopo;
- Ridotta complessità delle strutture di dati prodotte (vedi Open Data Format).

Il software prodotto deve essere estremamente semplice per il suo deployment, con massimo due righe di comando da eseguire su di un VPS a basso costo, per replicare l'intera scansione e data set in massimo 24 ore.

Una linea di possibile design implementativo è quella di usare i pattern del software GHIDRA di reverse engineering, cioè tanti tool esterni che comunicano tramite interfaccia di input/out stdio (tecnicamente una pipe).

Questo pattern riduce il numero delle dipendenze e la complessità di mantenere i software, senza necessità di binding di librerie native.

Le fonti dati per la costruzione dei dataset devono essere caricate dinamicamente dal software, per la massima replicabilità.

Una copia offline viene fornita come dati già inclusi e re-distribuiti come parte del software.

Politica di pubblicazione

È necessario partire dall'assunzione che le informazioni che OSSCI vuole divulgare sono già pubblicamente disponibili tramite i numerosi sistemi di scansioni automatiche online, oltre ad essere disponibile ai threat actors che possono ottenerle in pochi minuti.

Per tale motivo, nonostante possa non apparire ovvio ai non addetti al settore, i dati saranno pubblicati secondo un principio di full disclosure, non contenendo alcun tipo di dato o informazione che possa facilitare attacchi o aggressioni informatiche verso le infrastrutture dello spazio cibernetico italiano.

La presenza delle informazioni di scansione con tipo di software e versione è già esistente su servizi di Internet scan come ad esempio Shodan (servizio gratuito di base ma a pagamento per funzionalità più avanzate) o Censys che pure offre un programma di accesso ai dati di scansione per finalità di ricerca (a cui potremmo fare richiesta di accesso, sempre che le condizioni di licenza d'uso dei dati siano libere, in considerazione delle finalità di stimolo alla ricerca aperta dell'osservatorio).

Sono esistenti applicazioni software di scansione massiva di Internet quali zmap, che dichiara di poter scansionare tutta Internet in meno di un'ora usando un computer desktop.

I threat actors, cioè coloro che con finalità malevole scansionano le reti, già impiegano questi tipi di strumenti in azioni più o meno sofisticate, più o meno su larga scala.
Tuttavia gli specialisti della sicurezza cibernetica non possono avere la disponibilità delle medesime informazioni dei threat actors, per finalità difensive.

La pubblicazione di tali informazioni vuole favorire la messa in sicurezza dei servizi Internet offerti dal ciberspazio italiano, permettendo al pubblico, ai soggetti interessati e alla comunità di specialisti di settore di fare ricerca introducendo soluzioni innovative e ad alta efficacia operativa, quali sistemi automatici di rilevamento e notifica delle vulnerabilità più evidenti.

È doveroso sottolineare che le basi dati che vengono costruite sono, come dimostra il software che le produce, per lo più derivanti dalla acquisizione e interpolazione di basi dati apertamente disponibili (es: sarebbe possibile addirittura non effettuare alcuna scansione proattiva, impiegando dati di Shodan, Censys o altri Internet scan pubblici per la Pipeline 1).

Licenza di distribuzione del software e dei dati

Di particolare rilevanza, ai fini dello sviluppo scientifico del progetto, l'applicazione delle dovute licenze sia per quanto attiene al software tanto per quanto riguarda i dati prodotti dalle varie pipeline di elaborazione del software.

Il software verrà rilasciato sotto licenza libera OSI certified Affero GPL versione 3.0 (AGPLv3).

I dati prodotti non possono avere una licenza, forzata dal software come output, ma quelli re-distribuiti potrebbero essere posti sotto una licenza Open Data di tipo waiver, come la Creative Commons - zero (CC0) .

Gestione operativa della produzione dati

Un tema specifico del progetto è quello necessario alla gestione operativa della produzione dei dati, specificamente a partire dalla Pipeline 1: Asset Inventory Nazionale per la sua natura di interattività con una numerosa quantità di reti e sistemi (si stimano >20 milioni di IP).

Operatività legale

Nonostante vi siano diversi servizi di massive Internet scanning, quello dell'osservatorio sarà realizzato da parte di italiani con obiettivi di miglioramento della sicurezza italiana.

È possibile che aziende pubbliche o private male interpretino le finalità difensive delle scansioni ricevute e/o dei risultati presenti nei dataset in elaborazioni di terzi (es: sistemi di comparazione fra organizzazioni dello stesso settore con incentivo reputazionale, che può essere oggetto di media coverage).

Per tale motivo è necessario porre grande attenzione ad adottare, pubblicamente, tutte le misure necessarie affinché i soggetti giuridici, in particolare le pubbliche amministrazioni e i soggetti coinvolti in un'eventuale minaccia legale siano educati e informati degli obiettivi, metodi e finalità del progetto.

A tale riguardo dovrà essere definita una procedura di gestione:

1. Fornire una pagina di spiegazione della liceità dell'operazione sul sito;
2. Fornire una pagina di contatto legale in modo chiaro sul sito (inclusa PEC);
3. Pubblicamente prendere posizione che questo è un progetto comunitario e che qualunque minaccia legale sarà condivisa pubblicamente con la comunità attraverso i forum e i gruppi comunitari su chat e social media.

Tali approcci dovrebbero rappresentare un adeguato deterrente, tale da prevenire azioni legali vere e proprie ed a favorire la comprensione nella comunità della esistenza di questo progetto e dei suoi aspetti di funzionamento.

Certamente interessanti sono le risorse di analisi legale dei seguenti progetti già attivi di Internet scanning:

- Rapid7 (che scansiona Internet dal 2013 dagli USA)

- Nmap (strumento di portscanning molto diffuso)

Comunicazione preventiva alle istituzioni

È necessario portare avanti una forma di comunicazione con le istituzioni, per informarle del progetto e delle scansioni che arriveranno, oltreché degli eventuali alert e avvisi per possibili problematiche.

Questa informazione preventiva al mondo della pubblica amministrazione sarà effettuata tramite comunicazione massiva dalla base dati IndicePA tenuta dall'AGID, con comunicazione indirizzata all'URP alla attenzione, ad esempio, del RTD (Responsabile alla Transizione Digitale).

Sarà altresì necessario fare una comunicazione a tutte le procure e divisioni di Polizia Postale d'Italia, al CNAIPIC, al Nucleo Operativo per la Sicurezza Cibernetica e al DIS, con questi stabilendo contact point relativi alla notorietà degli IP di scansioni.

Informare le istituzioni preposte a vario titolo e grado alla sicurezza cibernetica diventa una priorità per gestire eventuali richieste relative a detti scan.

In particolare saranno tutti informati degli scopi del progetto ma anche degli indirizzi IP, hostname e netblock relativi all'origine degli scan, nonché contact point per le varie esigenze.

Comunicazione preventiva a operatori di telecomunicazioni

È necessario preventivamente avvisare tutti gli operatori del settore delle telecomunicazioni, siano essi Internet service provider, datacenter provider o cloud provider.

A tale scopo saranno informati:

- Tutti gli operatori di telecomunicazioni italiani con rilevanza nazionale
- Tutti gli intestatari e/o contact point dei netblock di provenienza RIPE NCC parte della Pipeline 0
- Tutti gli intestatari e/o contact point degli Autonomous System di provenienza BGP parte della Pipeline 0 (che sono afferenti agli Internet exchange italiani)
- Tutti gli afferenti ad AIIP (Associazione Italiana Internet Provider) e Assoprovider

Saranno ulteriormente informati i principali Cloud Provider internazionali, che già hanno fornito comunque una autorizzazione preventiva alle attività di analisi di sicurezza sulle loro infrastrutture:

- Microsoft Azure Rules of Engagement & Penetration Testing Notification
- Amazon AWS Customer Support Policy for Penetration Testing

Accettazione Termini di Utilizzo dei Dati

Il soggetto giuridico che opererà la distribuzione dei dati prodotti delle varie pipeline potrà, a maggior tutela, richiedere l'accordo contrattuale con una accettazione di Termini d'uso dei dati propedeutica al download.

I termini di utilizzo propedeutici al download potranno prevedere l'esplicito consenso all'utilizzo per finalità di ricerca legittime, volte al miglioramento della sicurezza dello spazio cibernetico italiano, esplicitamente vietando l'impiego per qualunque attività che possa ledere diritti di terzi, a titolo di esempio tentativi di accesso abusivo non autorizzato.

Sorgenti IP delle attività

Gli indirizzi IP sorgenti delle attività saranno resi pubblici sul sito web, con indirizzi di reverse DNS e whois auto-esplicativi.

L'obiettivo è massimizzare la comprensione che non si tratta di una scansione con finalità malevola, ma come già per altre iniziative di massive Internet scanning, rendere palese chi sta effettuando la scansione e con quali finalità.

Sarà poi eventuale interesse o azione di chi gestisce le infrastrutture, bloccare questi IP rispetto alle scansioni continuative.
Gli indirizzi IP di scansione saranno comunque variati regolarmente (e.g. ogni 6-12 mesi) per garantire che le informazioni relative allo SCI siano sempre aggiornate, al netto dei blocchi eventualmente impostati sulle infrastrutture.

Spazi IP di scansione e Abuse

Come ogni scansione su Internet, seppur non malintenzionata, potrà ingenerare delle abuse request.
Per tale ragione è necessario che lo spazio di IP da cui verranno effettuate le scansioni:

- Abbia un netblock che da "WHOIS" sia chiaramente identificabile nel progetto OSSCI;
- Abbia un abuse contact dedicato con indicato che tutte le richieste saranno rese pubbliche.

L'obiettivo è che tutte le richieste di abuse saranno automaticamente pubblicate online per la sua gestione in modo collaborativo, eventualmente su una sezione ad hoc di un forum (discourse?).

Esperienze di Internet scanning all’estero

Nel mondo sono molte le altre esperienze di Internet scanning, oggi coadiuvate da strumenti automatici ad alta efficienza quali ad esempio zmap.

Sono inoltre molte le basi dati di scansioni complete di Internet, incluso lo spazio cibernetico italiano oggetto del presente progetto, talune completamente pubbliche altre ad accesso su richiesta, altre ad accesso limitato.

Fra le iniziative più interessanti a cui l’osservatorio può ispirarsi sotto il profilo tecnico e/o per l’acquisizione di dati di scansione da elaborare troviamo:

Nome Progetto	**Sito**	**Descrizione**
Scans.io	https://scans.io/	Indice di siti che forniscono dati di Internet scan
Censys Internet Scan	https://censys.io/product/data	Scansione massiva di Internet con dati aperti ricercabili in modo massivo simile a shodan
Shodan	https://www.shodan.io/	Servizio free/freemium di Internet scanning con massima accessibilità e ricerca
Project 25499	http://project25499.com/	Scansione massiva amatoriale e pro bono aggiornata di Internet con 5 server
ShadowServers	https://wiki.shadowserver.org/wiki/	Progetto di alerting proattivo Internet-wide di vulnerabilità